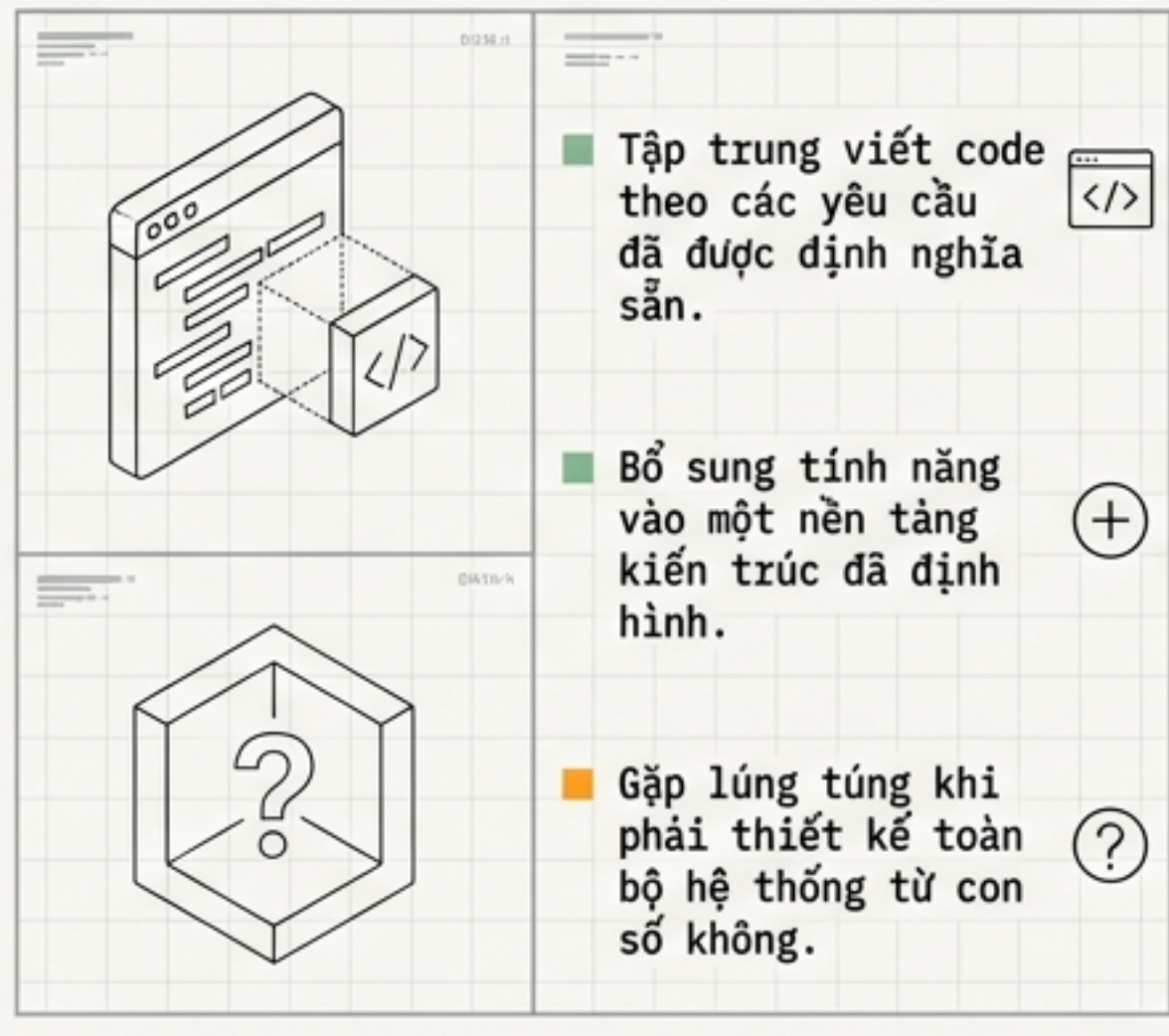
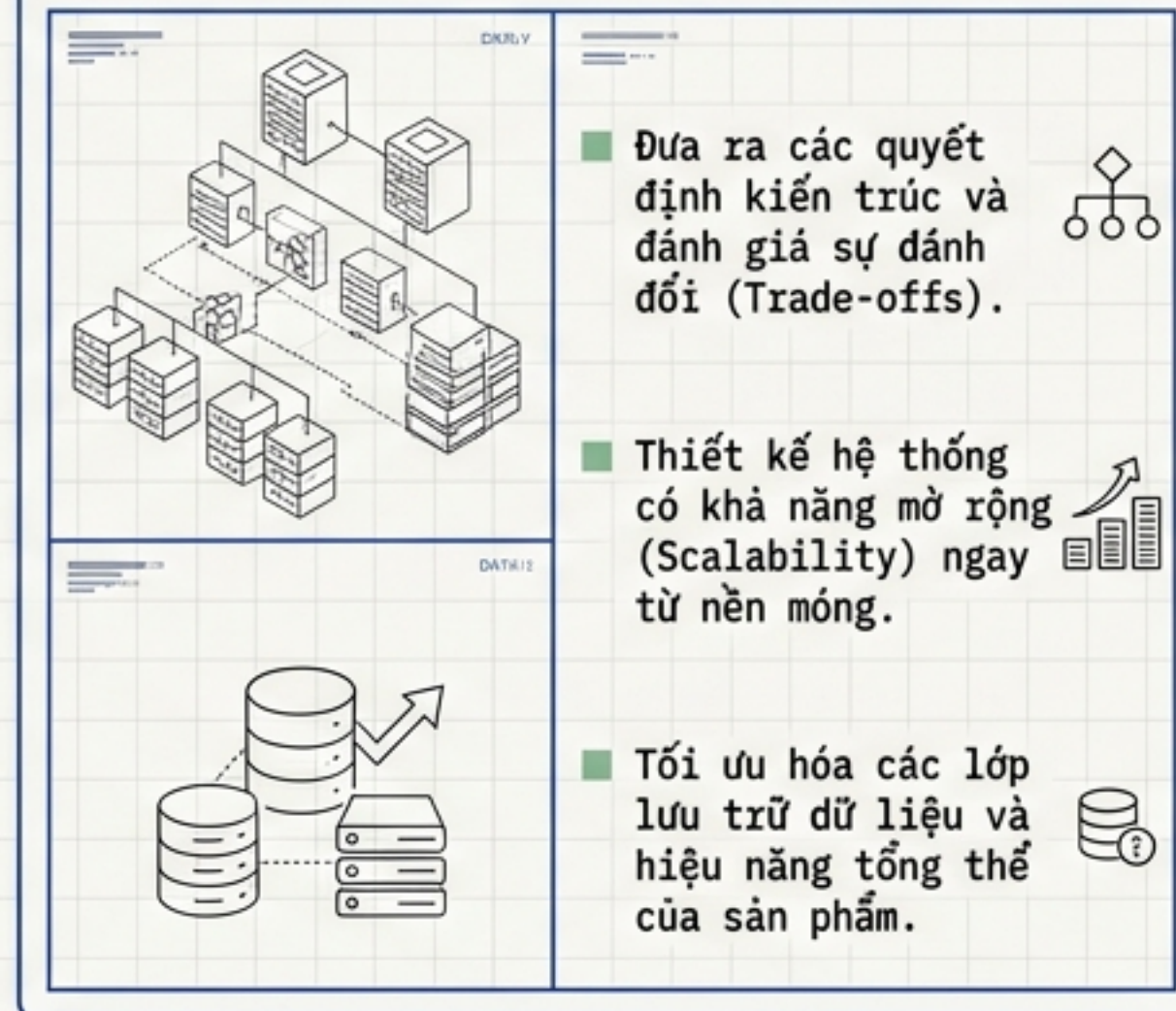


BẢN THIẾT KẾ HỆ THỐNG KỸ THUẬT PHẦN MỀM

Lập Trình Viên (Mid-level)

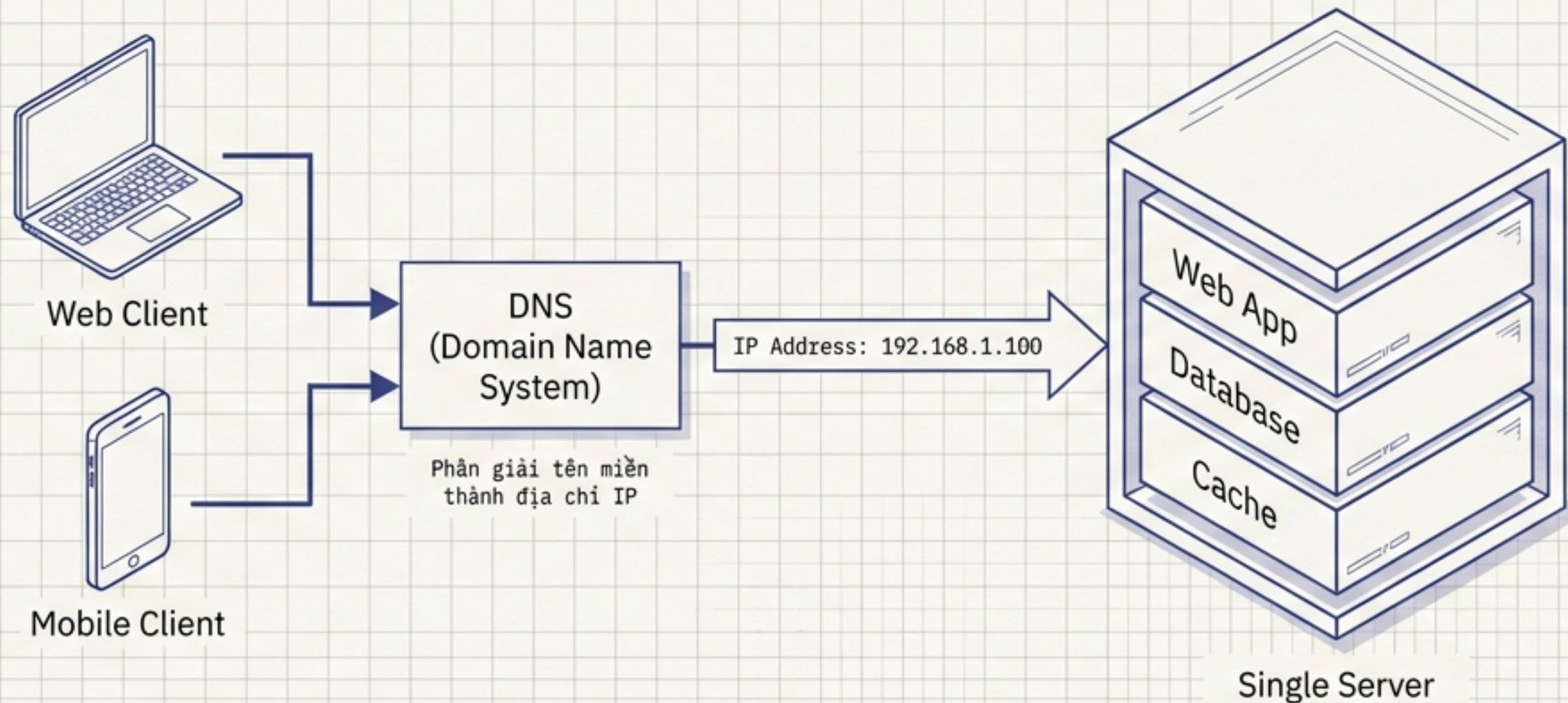


Kỹ Sư Hệ Thống (Senior)



Kỹ năng thiết kế hệ thống vĩ mô chính là ranh giới thực sự phân định giữa một lập trình viên thông thường và một kỹ sư cấp cao.

Nền Móng: Kiến Trúc Single Server

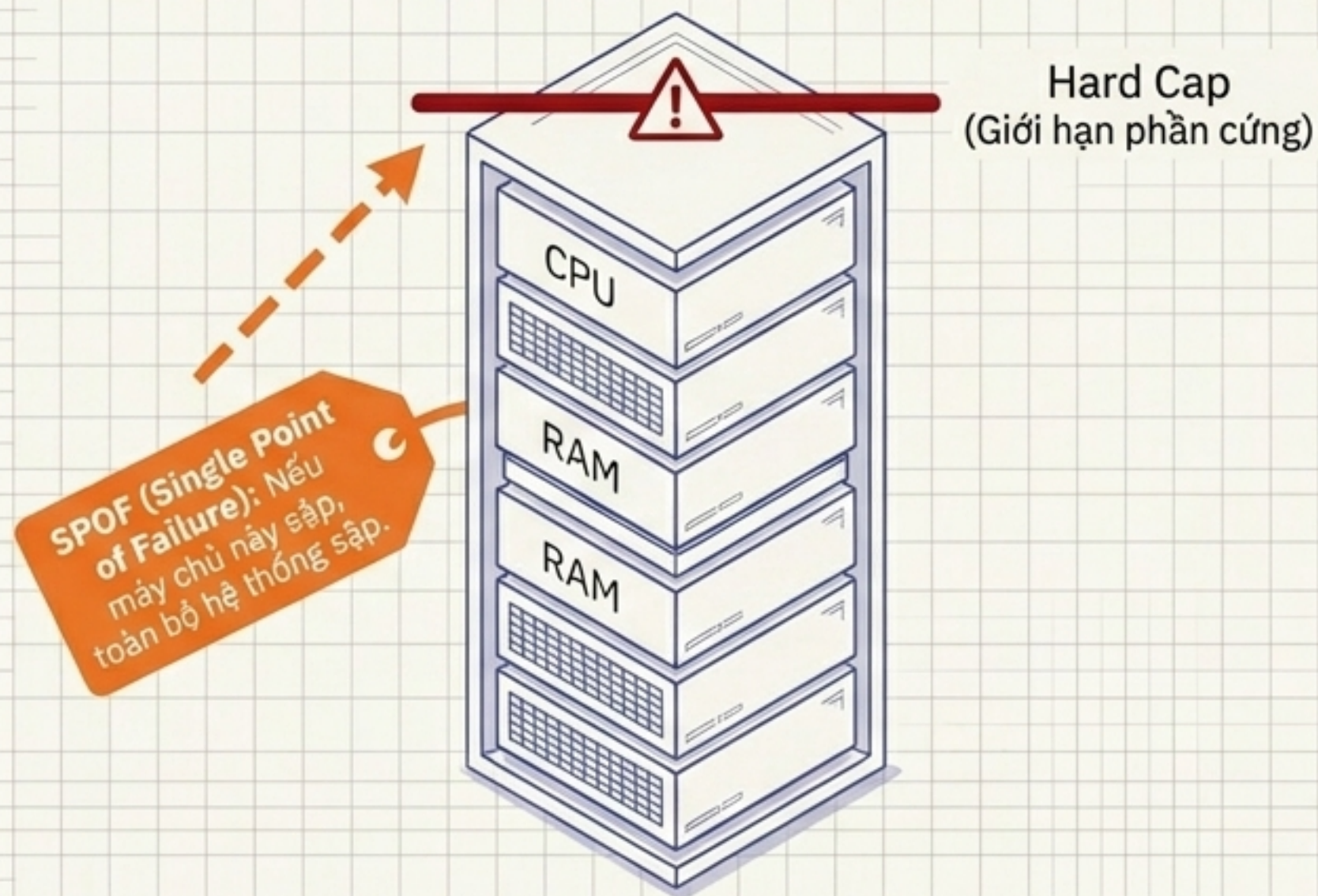


- Gộp chung mọi thành phần (Web, DB, Cache) vào một máy chủ duy nhất.
- Web Request: Giao tiếp qua HTTP, trả về HTML/CSS/JS.
- Mobile Request: Giao tiếp qua HTTP API, trả về JSON.

⚠ Cảnh báo: Giải pháp lý tưởng để khởi tạo, nhưng sẽ bộc lộ điểm yếu chí mạng khi lưu lượng người dùng tăng đột biến.

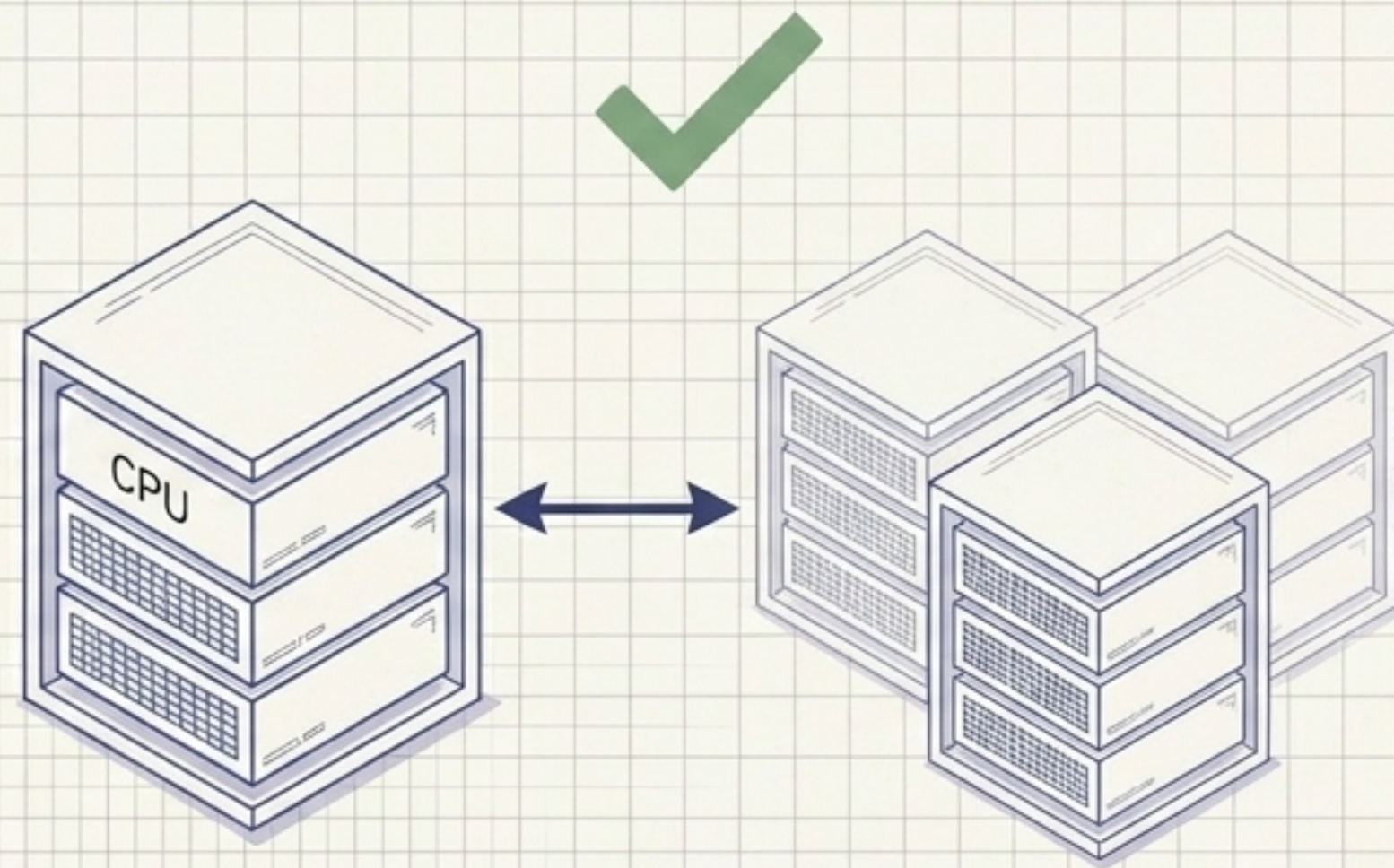
Bài Toán Mở Rộng & Điểm Nghẽn Chí Mạng

Vertical Scaling (Scale Up)



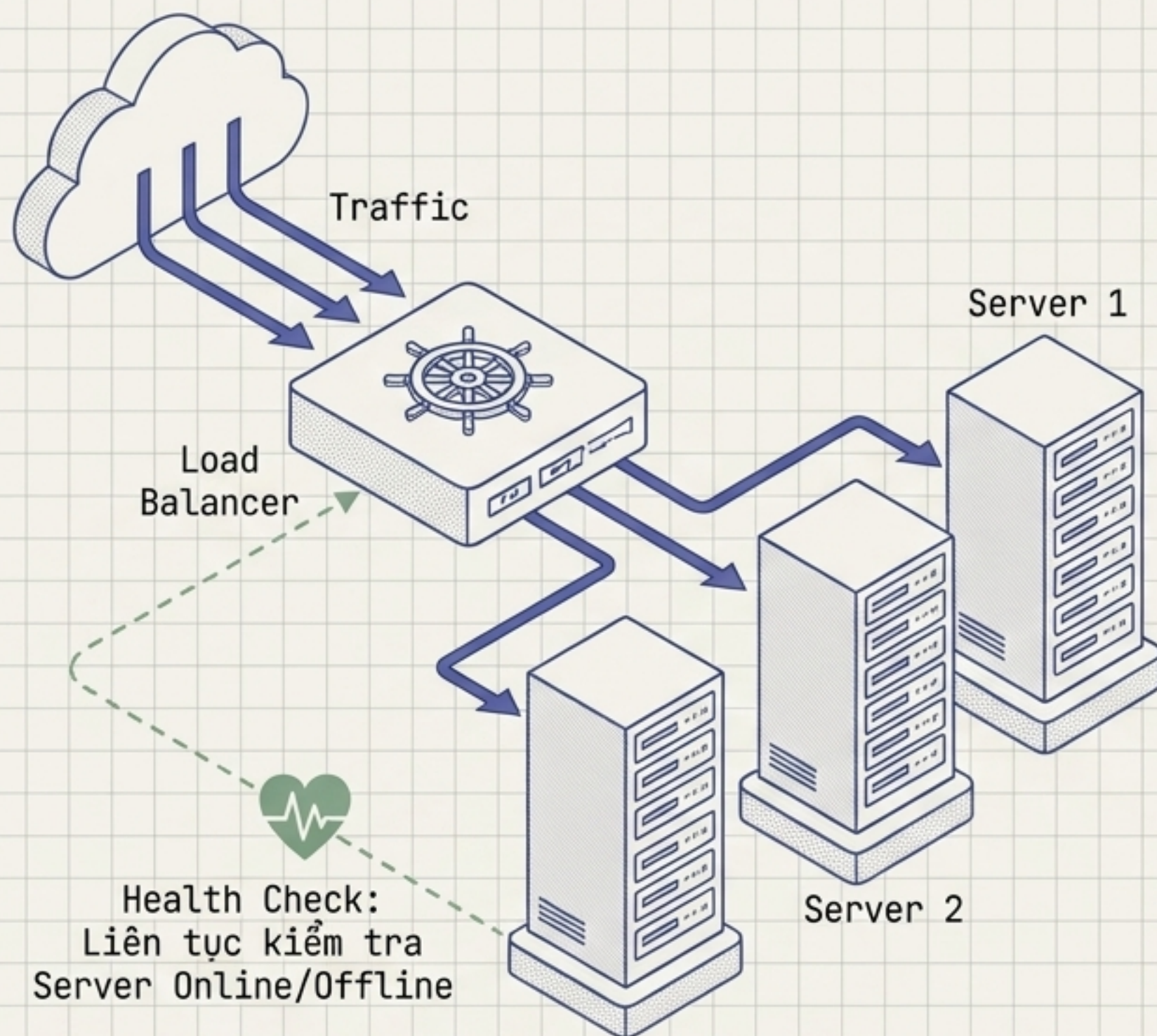
Nâng cấp trực tiếp sức mạnh cho một máy chủ.
Nhược điểm: Bị giới hạn vật lý và thiếu tính dự phòng.

Horizontal Scaling (Scale Out)



Nhân bản nhiều máy chủ nhỏ chia sẻ tải trọng.
Ưu điểm: Tăng tính dự phòng (Fault tolerance) và khả năng mở rộng không giới hạn.

Bộ Điều Phối Giao Thông: Load Balancer



7 Thuật toán

1	Round Robin	Xoay vòng tuần tự (1 -> 2 -> 3 -> 1).
2	Least Connections	Điều hướng đến Server đang có ít kết nối nhất.
3	Least Response Time	Ưu tiên Server có tốc độ phản hồi nhanh nhất.
4	IP Hash	Bắt địa chỉ IP, đảm bảo một client luôn kết nối lại một Server cố định.
5	Weighted	Phân bổ theo trọng số cấu hình (Server mạnh gánh nhiều tải hơn).
6	Geographical	Điều hướng theo vị trí địa lý của người dùng.
7	Consistent Hashing	Phân phối qua vòng băm (Hash Ring), tối ưu hóa khi thêm/bớt Server.

Ma Trận Ra Quyết Định Kiến Trúc Dữ Liệu



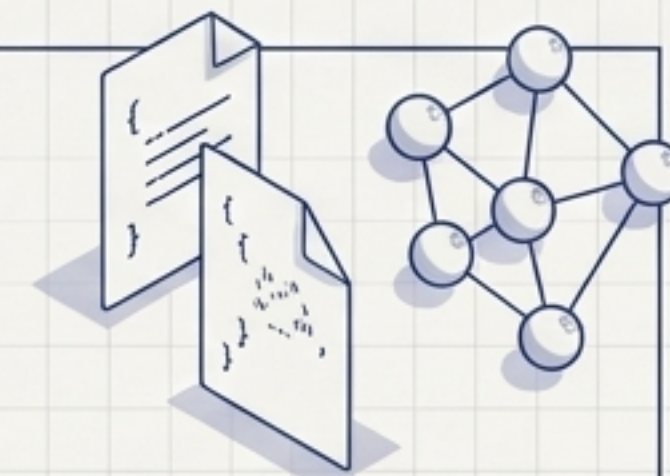
SQL (Cơ Sở Dữ Liệu Quan Hệ)

Ví dụ: PostgreSQL, MySQL, Oracle.

Cấu trúc: Dữ liệu tổ chức thành Bảng (Tables) & Hàng (Rows), liên kết chặt chẽ bằng chuỗi JOIN.

Đặc tính: Đảm bảo giao dịch ACID tuyệt đối (Atomic, Consistent, Isolated, Durable). Tính nhất quán dữ liệu ở mức cao nhất.

Use-case: Hệ thống tài chính ngân hàng, thương mại điện tử, ứng dụng có ràng buộc dữ liệu nghiêm ngặt.



NoSQL (Cơ Sở Dữ Liệu Phi Quan Hệ)

Ví dụ: MongoDB, Cassandra, Redis, Neo4j.

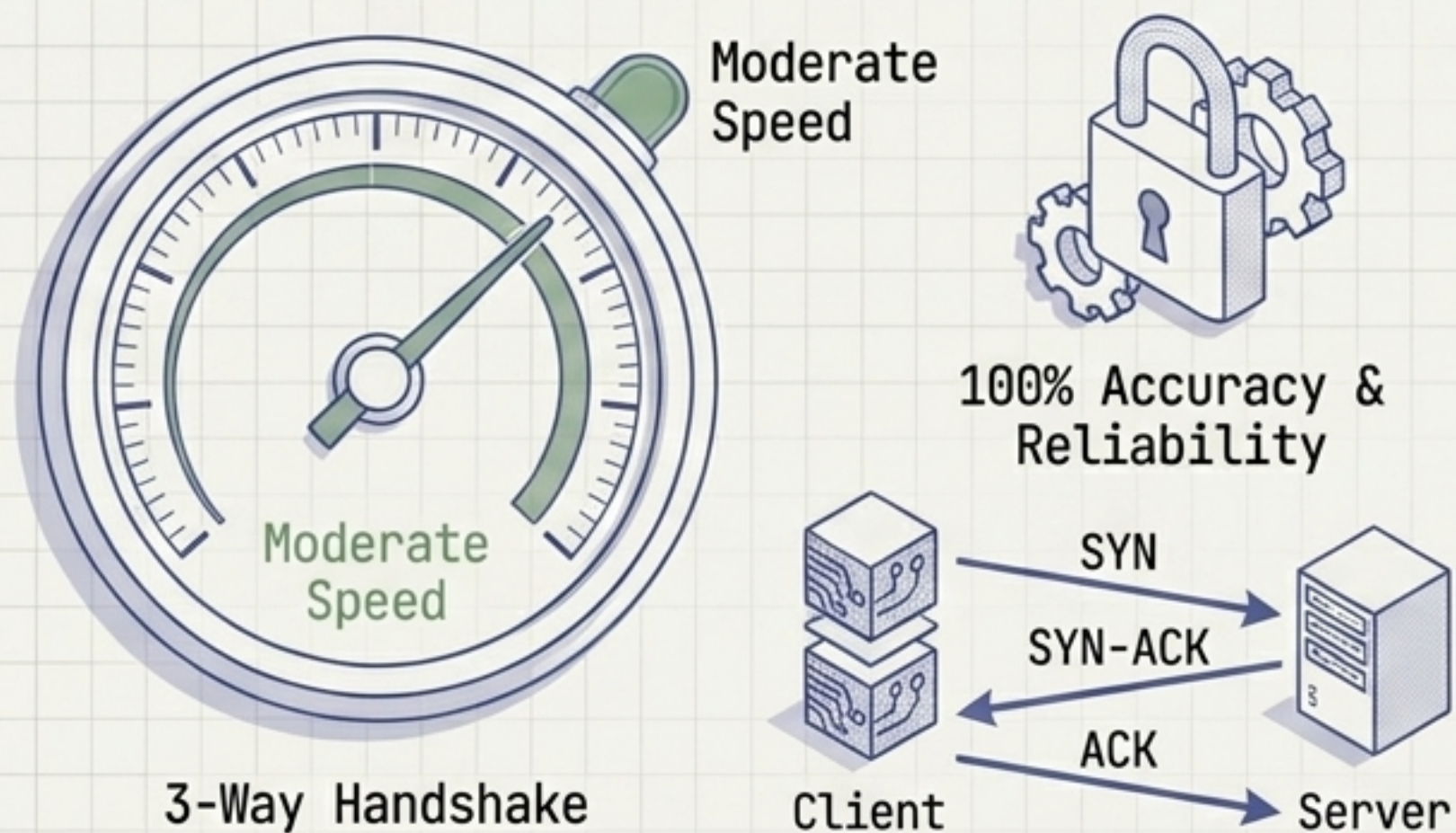
Cấu trúc: Đa dạng định dạng (Document JSON, JSON, Wide-Column, Key-Value, Graph).

Đặc tính: Tính linh hoạt cực cao, độ trễ thấp (Low Latency), cấu trúc tối ưu để Scale Horizontal.

Use-case: Dữ liệu phi cấu trúc, Big Data, phân tích Real-time, mạng xã hội, hệ thống đề xuất (Recommendations).

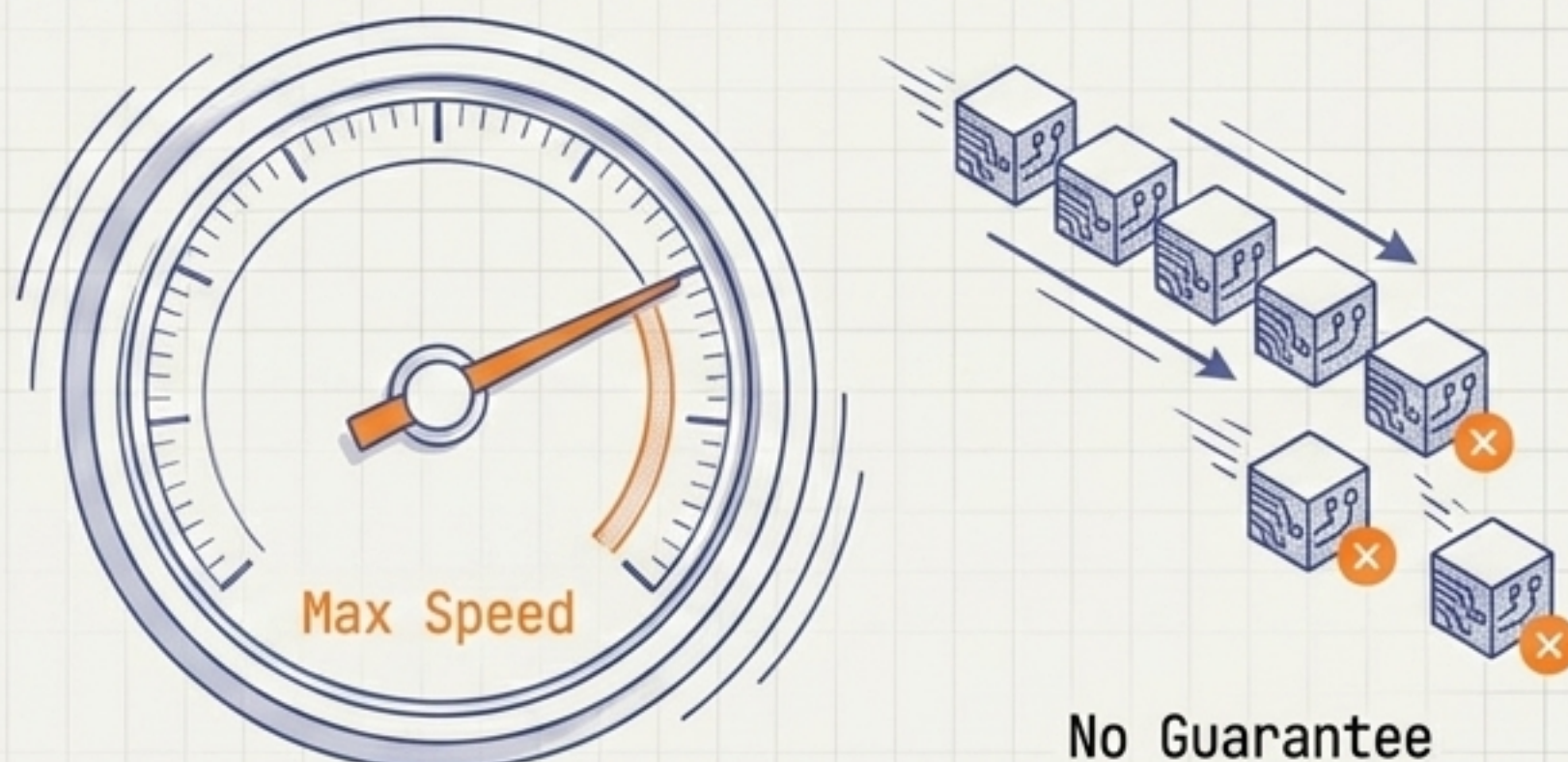
Tầng Vận Chuyển (Transport Layer): TCP vs UDP

TCP (Transmission Control Protocol)



- **Đặc điểm:** Chậm nhưng an toàn tuyệt đối. Đảm bảo thứ tự gói tin, tự động truyền lại nếu có gói tin bị thất lạc (Reliable).
- **Ứng dụng:** Cổng thanh toán, Email, Truyền tải dữ liệu người dùng.

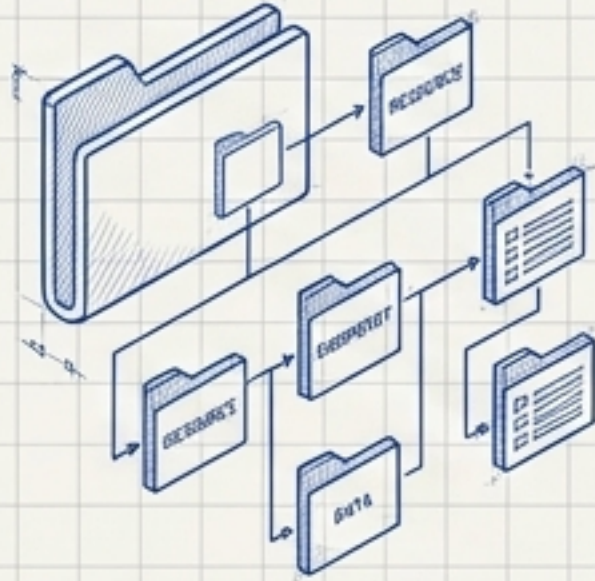
UDP (User Datagram Protocol)



- **Đặc điểm:** Tốc độ tối đa. Không bảo đảm kết nối, không truyền lại gói tin lỗi. Truyền tải nhanh, nhẹ nhưng chấp nhận rủi ro mất mát dữ liệu.
- **Ứng dụng:** Video call, Livestream sự kiện trực tiếp, Gaming trực tuyến tốc độ cao.

Phân Rã Và So Sánh 3 Kiến Trúc API

REST

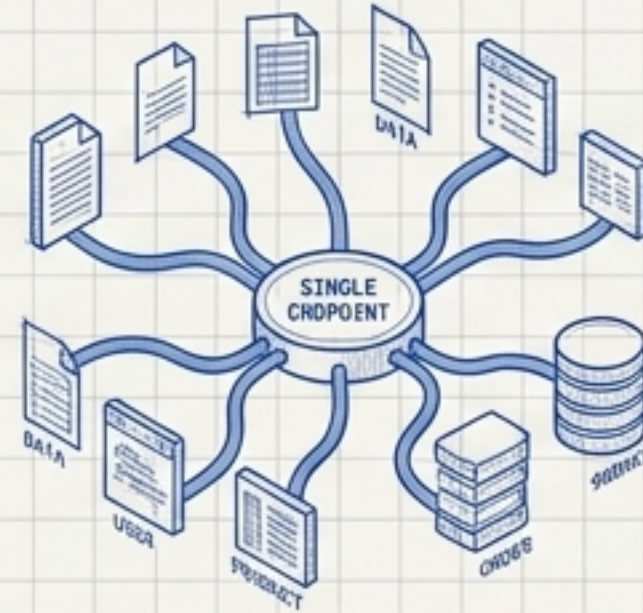


Cơ chế: Hoạt động dựa trên Tài nguyên (Resource-based). Cung cấp nhiều endpoints cố định. Cấu trúc dữ liệu trả về tĩnh và định sẵn.

Giao thức: Chạy trên HTTP thuần túy. Khả năng hỗ trợ bộ nhớ đệm (Cache) xuất sắc.

Chuẩn mực phổ biến nhất cho Web/Mobile.

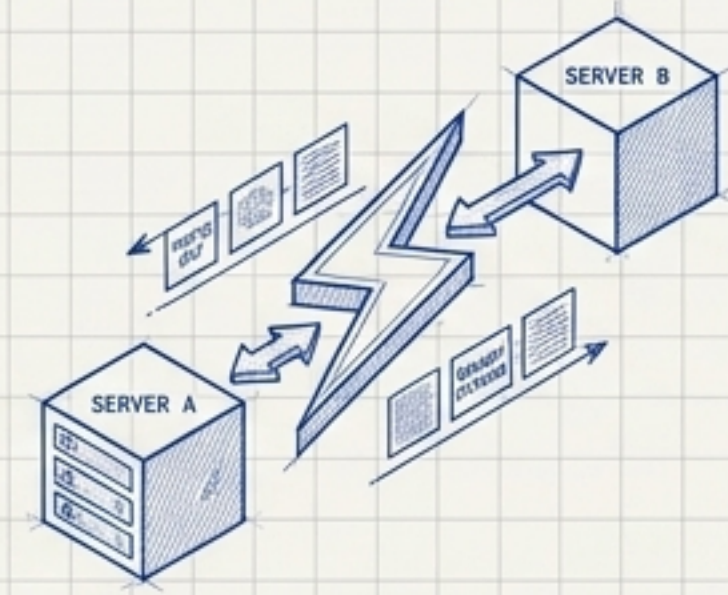
GraphQL



Cơ chế: Giao tiếp qua một Endpoint duy nhất. Client định đoạt chính xác dữ liệu cần nhận, loại bỏ hoàn toàn vấn đề thừa dữ liệu (chống Over-fetching).

Use-case: Hệ thống có UI/UX phức tạp, cần gom nhặt dữ liệu từ nhiều nguồn khác nhau vào trong một Request duy nhất.

gRPC

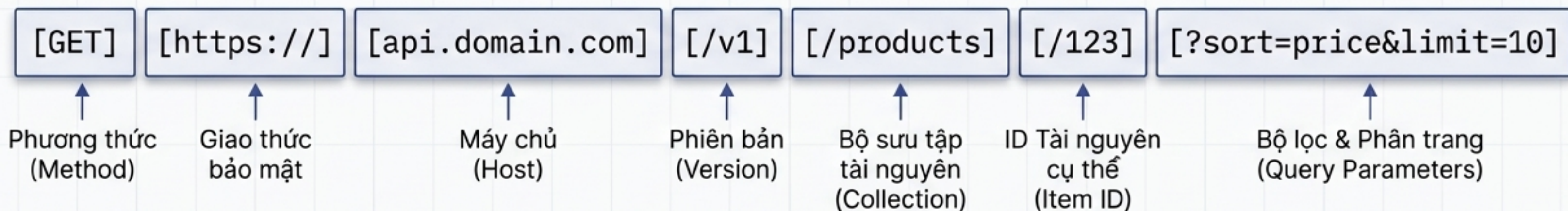


Cơ chế: Gọi thủ tục từ xa với hiệu năng siêu cao, đóng gói dữ liệu bằng Protocol Buffers.

Giao thức: Bắt buộc vận hành trên HTTP/2. Giao tiếp dạng nhị phân (Binary) và hỗ trợ Streaming hai chiều.

Use-case: Tối ưu cho giao tiếp nội bộ Server-to-Server (Microservices).

Giải Phẫu Cấu Trúc Bề Mặt REST API



Thẻ chức năng HTTP Methods

"GET": Đọc dữ liệu (An toàn & Idempotent).

"POST": Tạo tài nguyên mới.

"PUT": Ghi đè/Thay thế toàn bộ tài nguyên.

"PATCH": Cập nhật một phần tài nguyên.

"DELETE": Xóa tài nguyên.

Quy chuẩn Lọc

The UI mockup shows three sections of controls for API filtering:

- Danh mục**: A range slider with a value of `x`, resulting in the query parameter `?category=x`.
- Chiều sắp xếp**: A toggle switch set to `asc`, resulting in the query parameter `?sort=asc`.
- Page and Limit**: A gauge showing page 2, and two input fields for page number (2) and limit (10), resulting in the query parameters `?page=2&limit=10`.

Ghi chú: Hạn chế Over-fetching và tối ưu bằng thông.

Trạng Thái Phản Hồi (Status Codes) & Xử Lý Ngoại Lệ

Status Panel

20x - Thành Công (Success)

200 OK	Thành công chung cho mọi request.	
201 Created	Tạo tài nguyên mới thành công.	
204 No Content	Thành công nhưng không có dữ liệu trả về (thường dùng cho DELETE).	

Status Panel

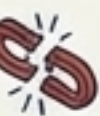
30x - Chuyển Hướng (Redirection)

300 Series Báo hiệu tài nguyên đã được di dời. 

Nhãn ghi chú
Client cần chuyển hướng đến một URL mới để lấy dữ liệu.

Status Panel

40x - Lỗi Phía Client

400 Bad Request	Tham số hoặc cú pháp gửi lên bị sai.	
401 Unauthorized	Thiếu hoặc sai thông tin xác thực định danh.	
403 Forbidden	Đã định danh nhưng không có quyền truy cập.	
404 Not Found	Sai URL hoặc tài nguyên không tồn tại.	

Status Panel

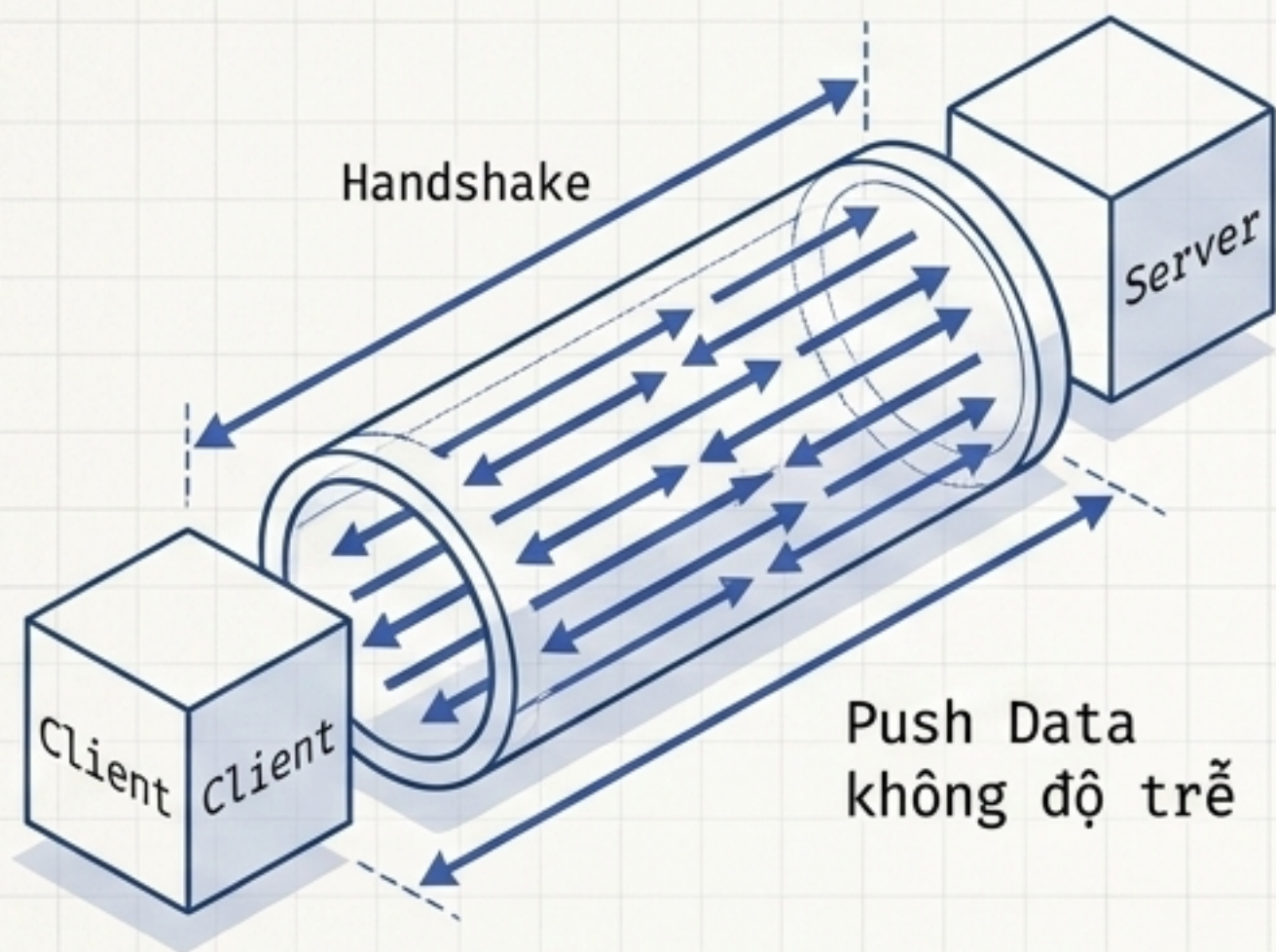
50x - Lỗi Phía Máy Chủ

500 Internal Server Error
Sập logic phía Backend hoặc lỗi kết nối Cơ sở dữ liệu. 

Nhãn ghi chú
Nhãn ghi chú: Lỗi hoàn toàn do hệ thống, client gửi đúng mọi thứ.

Vượt Ra Ngoài HTTP: Thời Gian Thực & Bất Đồng Bộ

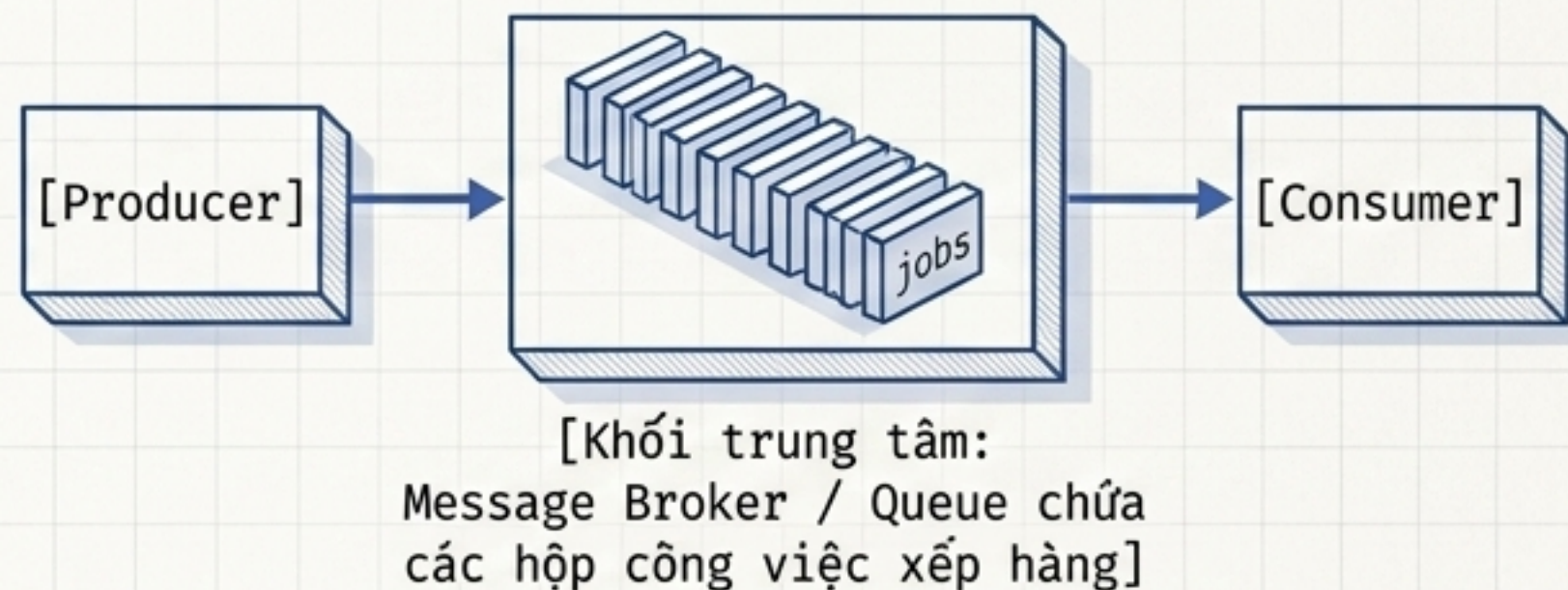
WebSockets (Real-time Giao Tiếp 2 Chiều)



Kết nối duy trì mở vĩnh viễn, Server có thể chủ động đẩy dữ liệu xuống Client.

Ứng dụng: Chat trực tuyến, Bảng giá chứng khoán (Trading), Cập nhật Live.

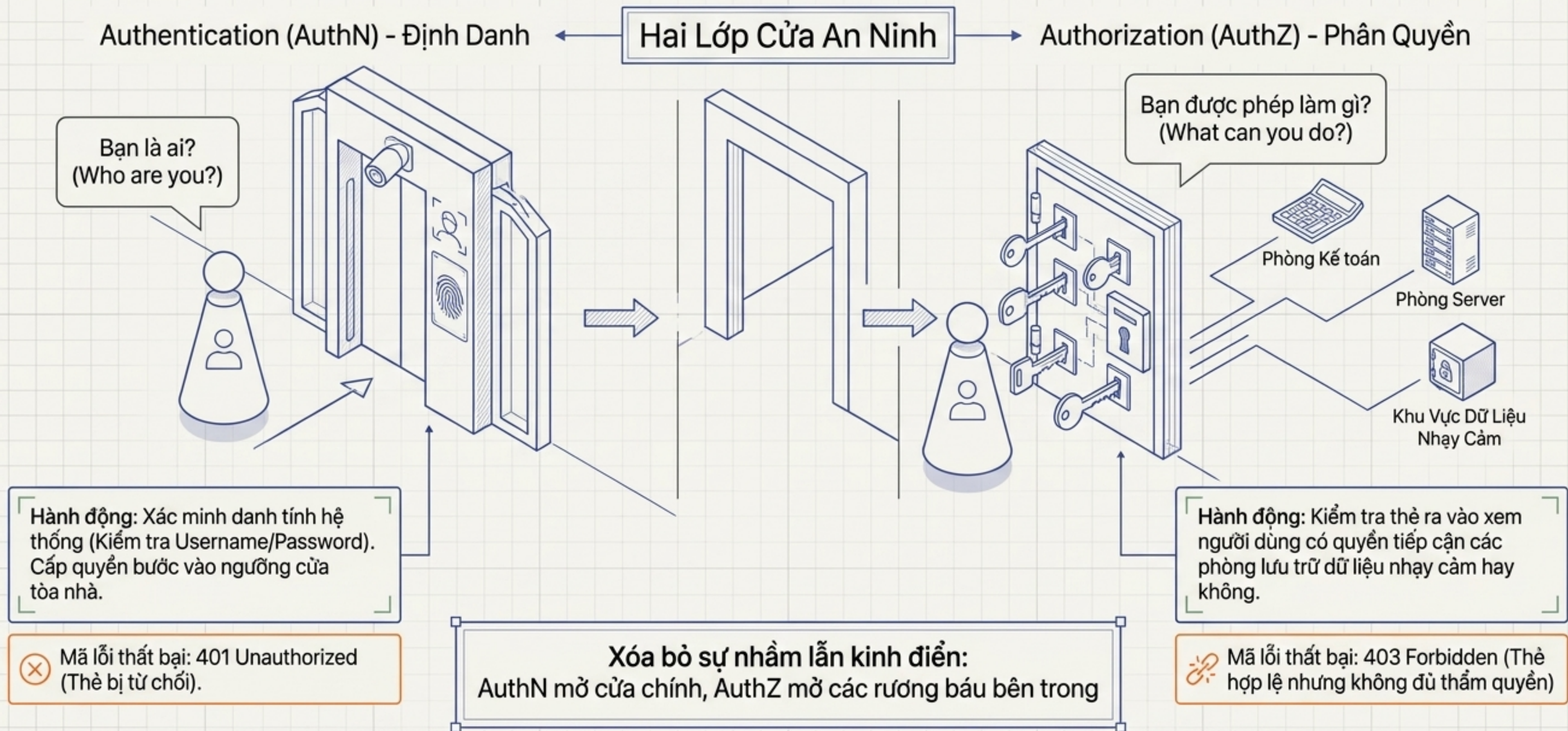
AMQP & Message Queues (Xử Lý Bất Đồng Bộ)



Tách rời (Decoupling) việc nhận yêu cầu và xử lý logic phức tạp. Hàng đợi lưu các tác vụ nặng để chống nghẽn Server.

Ứng dụng: Gửi hàng loạt Email, Xử lý kết xuất Video, Xử lý giao dịch ngầm.

Phân Định Rạch Ròi: Authentication vs Authorization



Sự Tiến Hóa Định Danh & Vòng Đời JWT

Trục thời gian tiến hóa (Evolution Timeline)



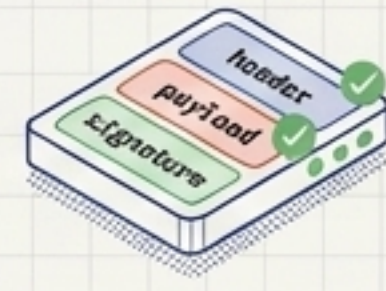
Basic Auth

Mã hóa **Base64** yếu, gửi liên tục trong mỗi Request.



Session-based

Lưu trạng thái tại Server (DB/Redis), rất khó Scale khi mở rộng ngang.



Token-based (JWT)

Stateless (Phi trạng thái), Server không cần lưu trữ, tự thân mã thông báo chứa đủ dữ liệu.

Sơ đồ luồng (Sequence Diagram) minh họa cơ chế Access & Refresh Token



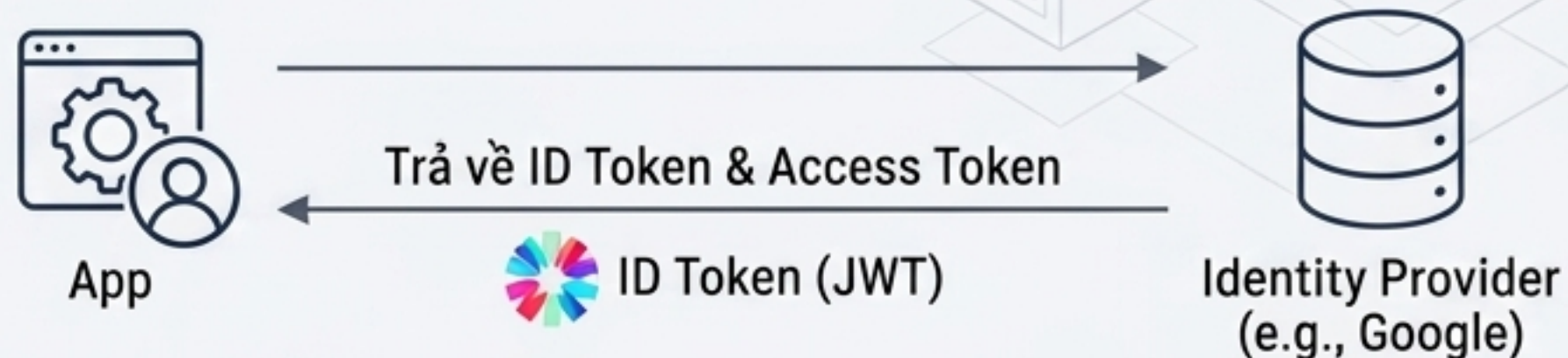
Các Khung Định Danh Hiện Đại: OAuth2 & OIDC

OAuth2 (Khung Ủy Quyền - Authorization)



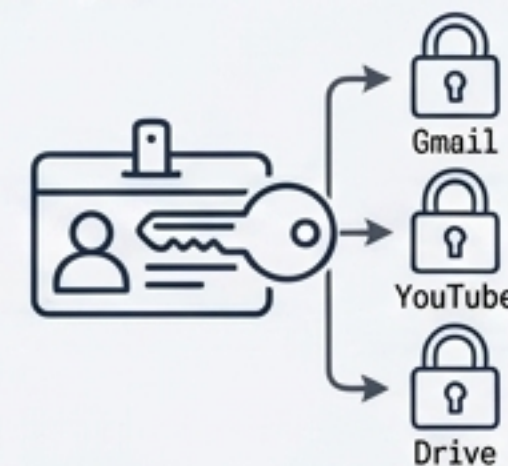
Nhấn mạnh: Đây là quá trình CẤP QUYỀN, hệ thống không hề biết danh tính thật của bạn là ai.

OpenID Connect (OIDC - Lớp Định Danh)



Bổ sung thêm một "ID Token" (thường dưới định dạng JWT). Token này gói gọn thông tin cá nhân cơ bản (Email, Profile, Avatar) giúp ứng dụng xác thực chính xác danh tính người dùng.

Note

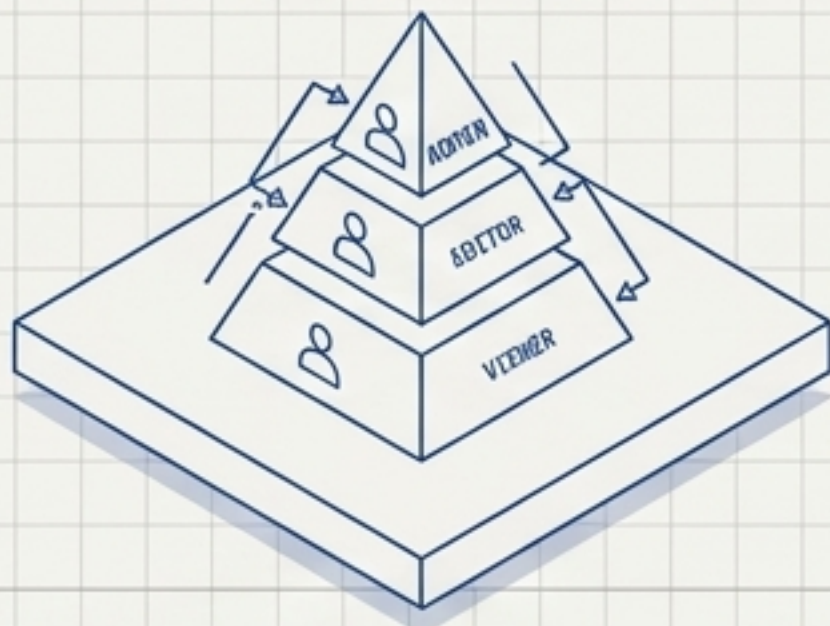


Cơ Chế Single Sign-On (SSO)

Nhờ OIDC/SAML, SSO cho phép
Nhờ OIDC/SAML, SSO cho đăng nhập 1 lần tại nền tảng Identity Provider (ví dụ: Google). Sử dụng cookie định tuyến chung để truy cập mọi dịch vụ nội sinh mà không cần nhập lại mật khẩu.

Thiết Lập Ranh Giới: 3 Mô Hình Phân Quyền (Authorization)

RBAC (Role-Based Access Control)



Cơ Chế (Mechanism):

Gắn quyền truy cập theo Vai trò cố định.

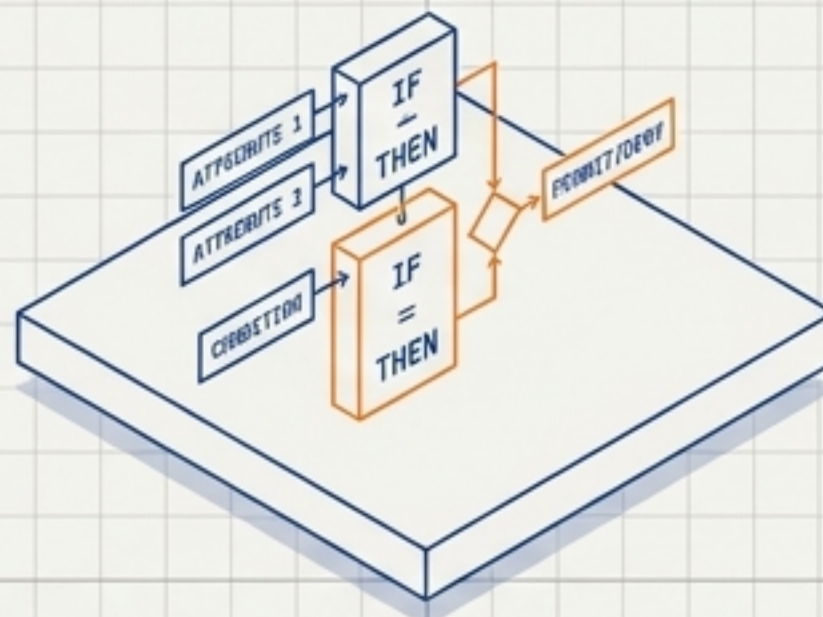
Ví dụ (Example):

Admin (Toàn quyền quản trị),
Editor (Đọc và Ghi nội dung),
Viewer (Chỉ được phép đọc).

Đánh giá (Evaluation):

- ✓ Phổ biến nhất, dễ thiết lập,
- ✓ dễ quản lý trên quy mô vừa.

ABAC (Attribute-Based Access Control)



Cơ Chế (Mechanism):

Gắn quyền theo Thuộc tính động và điều kiện logic phức tạp.

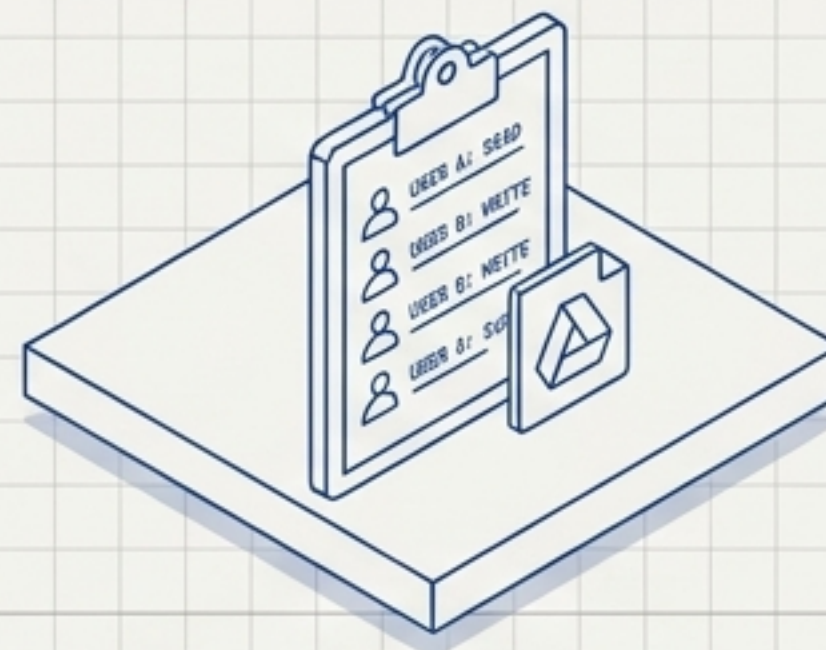
Ví dụ (Example):

NẾU (Phòng ban = HR)
VÀ (Thời gian = Giờ Hành Chính)
-> Cho phép truy cập hệ thống bảng lương.

Đánh giá (Evaluation):

- ✓ Cực kỳ linh hoạt, mức độ bảo mật cao nhất, nhưng tốn chi phí tính toán.

ACL (Access Control List)



Cơ Chế (Mechanism):

Danh sách kiểm soát đính kèm trực tiếp vào từng tài nguyên đơn lẻ.

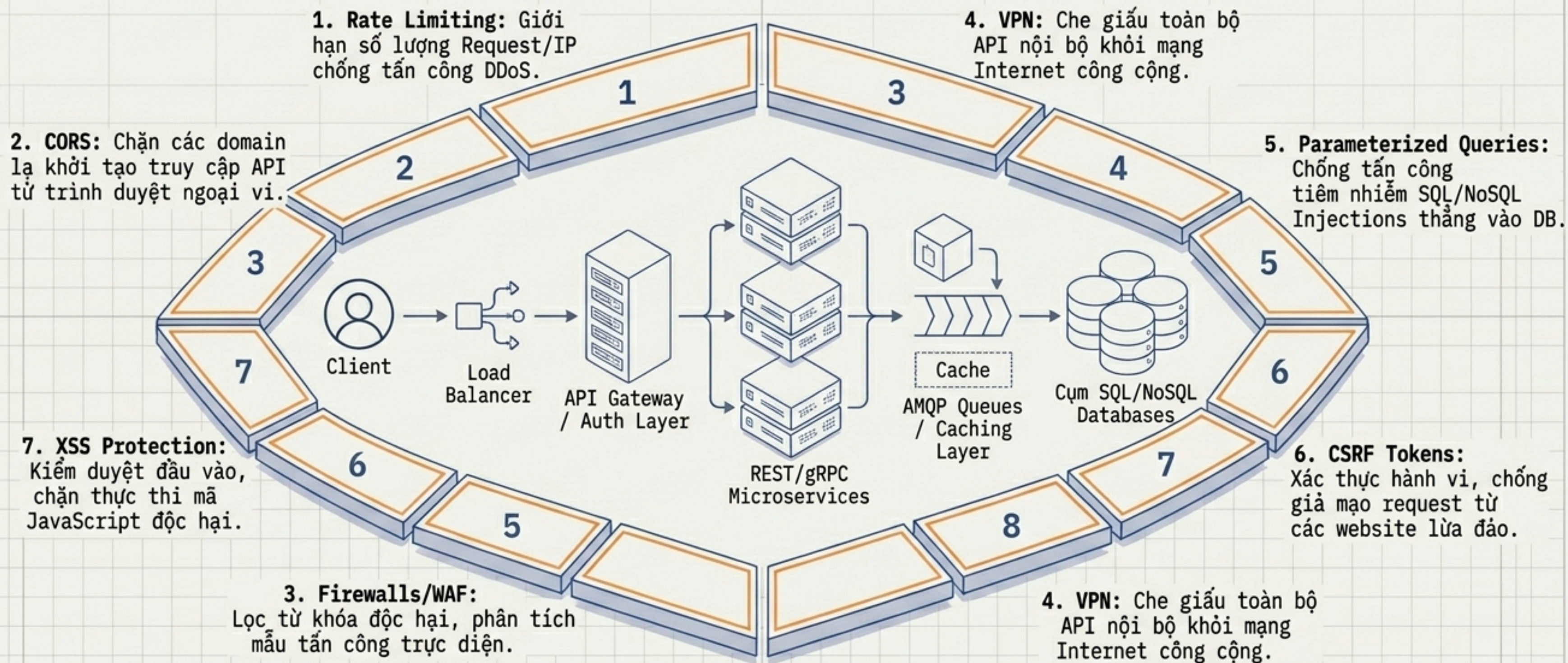
Ví dụ (Example):

Khung cấp quyền của Google Drive.
File Tài liệu X
-> Cho phép User A (Đọc), User B (Sửa).

Đánh giá (Evaluation):

- ✓ Cá nhân hóa cao độ, tối ưu khi chia sẻ tài nguyên ngang hàng.

The Master Blueprint: Pháo Đài Kiến Trúc Toàn Diện



Sự tiến hóa từ một đoạn code đơn lẻ trở thành một pháo đài kiến trúc bảo mật kiên cố.